

# Dependency Health Report — vulnerable-invoice-service

Generated: 2026-06-29T06:58:00Z | Health Score: **62 / 100 (Grade C)** | Trend: ↑ +62 vs. `main` (Grade D → Grade C)

## Executive Summary

- **8 dependencies** scanned · **70 CVEs** found on `main` · **60 CVEs cleared** by auto-remediation (Stages 1–3)
- **5 CRITICAL** dependencies → **0 CRITICAL** after remediation · 1 typosquatted dep removed · 1 untrusted HTTP repo removed
- Supply-chain: all BLOCK findings cleared · residual advisories are MAJOR\_REVIEW items requiring human decision
- Gate outcome: **PASS** (pending Stage 4 PR review post-push) · `mvn clean test` : 2/2 PASS
- Previous PR activity: 5 prior depscan PRs open and unmerged (PR #41, #42, #44, #48, #50) — all target same vulnerable `main`

## Health Score Breakdown

| Factor                               | Count              | Deduction   |
|--------------------------------------|--------------------|-------------|
| Unresolved CRITICAL CVE dependencies | 0 (was 5)          | 0 (was -75) |
| Unresolved HIGH CVE dependencies     | 3 × -8             | -24         |
| Unresolved MEDIUM CVE dependencies   | 7 × -2             | -14         |
| Supply-chain BLOCK findings          | 0 (was 2)          | 0 (was -20) |
| Outdated major-version deps          | 0                  | 0           |
| Score                                | 62 / 100 (Grade C) |             |

## Top Risks — Pre-Remediation (ranked by risk score)

| # | Coordinate                      | Risk | Band     | Top CVE                    | CVSS | Status               |
|---|---------------------------------|------|----------|----------------------------|------|----------------------|
| 1 | log4j-core:2.14.1               | 9.0  | CRITICAL | CVE-2021-44228 (Log4Shell) | 10.0 | ✓ Fixed → 2.17.1     |
| 2 | jackson-databind:2.9.8          | 9.0  | CRITICAL | CVE-2020-8840              | 9.8  | ✓ Fixed → 2.13.4.2   |
| 3 | log4j-api:2.14.1                | 9.0  | CRITICAL | CVE-2021-44228             | 10.0 | ✓ Fixed → 2.17.1     |
| 4 | mysql-connector-java:8.0.30     | 8.2  | CRITICAL | CVE-2023-22102             | 8.3  | ✓ Fixed → 8.0.33     |
| 5 | com.fastxml...:jackson-databind | 8.0  | CRITICAL | TYPOSQUAT                  | —    | ✓ Removed            |
| 6 | commons-io:2.4                  | 6.5  | HIGH     | CVE-2024-47554             | 7.5  | ✓ Fixed → 2.15.1     |
| 7 | guava:24.1.1-jre                | 6.3  | HIGH     | CVE-2023-2976              | 7.1  | ✓ Fixed → 32.0.0-jre |
| 8 | commons-lang3:3.4               | 5.8  | MEDIUM   | CVE-2025-48924             | 6.5  | ✓ Fixed → 3.14.0     |

## Remediation Activity (Stage 3)

| Dependency | old → new / action | CVEs cleared | Branch |
|------------|--------------------|--------------|--------|
|------------|--------------------|--------------|--------|

|                                                                                                   |                         |                                                      |                             |
|---------------------------------------------------------------------------------------------------|-------------------------|------------------------------------------------------|-----------------------------|
| log4j-core                                                                                        | 2.14.1 → 2.17.1         | CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), +5 more | fix/depscan-20260629-065427 |
| log4j-api                                                                                         | 2.14.1 → 2.17.1         | CVE-2021-44228 (10.0), CVE-2021-45046 (9.0)          | fix/depscan-20260629-065427 |
| jackson-databind                                                                                  | 2.9.8 → 2.13.4.2        | CVE-2020-8840 (9.8), CVE-2019-14540 (9.8), +53 more  | fix/depscan-20260629-065427 |
| guava                                                                                             | 24.1.1-jre → 32.0.0-jre | CVE-2020-8908, CVE-2023-2976                         | fix/depscan-20260629-065427 |
| commons-io                                                                                        | 2.4 → 2.15.1            | CVE-2021-29425, CVE-2024-47554                       | fix/depscan-20260629-065427 |
| commons-lang3                                                                                     | 3.4 → 3.14.0            | CVE-2025-48924                                       | fix/depscan-20260629-065427 |
| mysql-connector-java                                                                              | 8.0.30 → 8.0.33         | CVE-2023-22102 (8.3)                                 | fix/depscan-20260629-065427 |
| com.fastxml.jackson.core:jackson-databind                                                         | REMOVED                 | supply-chain typosquat                               | fix/depscan-20260629-065427 |
| <a href="http://insecure-mirror.example.net/maven2">http://insecure-mirror.example.net/maven2</a> | REMOVED                 | untrusted HTTP repo                                  | fix/depscan-20260629-065427 |

### Supply-Chain Findings

| Type           | Coordinate / Resource                                                                             | Detail                                                              | Action       |
|----------------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|--------------|
| TYPOSQUAT      | com.fastxml.jackson.core:jackson-databind:2.9.8                                                   | Impersonates <code>com.fasterxml</code> ; does not exist on Central | ✓ Removed    |
| UNTRUSTED_REPO | <a href="http://insecure-mirror.example.net/maven2">http://insecure-mirror.example.net/maven2</a> | Plain-HTTP Maven repo — MITM artifact injection risk                | ✓ Removed    |
| LICENSE_GPL2   | mysql:mysql-connector-java                                                                        | GPL-2.0 in permissive-only project; persists even after 8.0.33 bump | MAJOR_REVIEW |

### MAJOR\_REVIEW Items (human follow-up required)

| Coordinate                  | Advisory                                                      | Severity | Required Action                                                                         |
|-----------------------------|---------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------|
| mysql-connector-java:8.0.33 | GPL-2.0 + GHSA-m6vm-37g8-gqv                                  | HIGH     | Migrate to <code>com.mysql:mysql-connector-j:8.3+</code> (permissive license + CVE fix) |
| jackson-databind:2.13.4.2   | GHSA-j3rv-43j4-c7qm, GHSA-rmj7-2vxq-3g9f                      | HIGH     | Upgrade to 2.18.8 — major version review required                                       |
| log4j-core:2.17.1           | GHSA-3pxv-7cmr-fjr4, GHSA-vc5p-v9hr-52mj                      | MEDIUM   | Upgrade to 2.25.3/4 — API compatibility review required                                 |
| jackson-databind:2.13.4.2   | GHSA-3wrr-7qpf-2prh, GHSA-hgj6-7826-r7m5, GHSA-5jmj-h7xm-6q6v | MEDIUM   | Follow-up minor bump to 2.14–2.18.x                                                     |
| commons-lang3:3.14.0        | GHSA-j288-q9x7-2f5v                                           | MEDIUM   | Bump to 3.18.0 — safe minor, schedule next cycle                                        |

### Gate (Stage 4) — Verdict on Fix Branch

| Check | Result |
|-------|--------|
|-------|--------|

|                               |                                                                                       |
|-------------------------------|---------------------------------------------------------------------------------------|
| mvn clean test                | PASS — 2/2 tests                                                                      |
| OWASP CVE (0 CRITICAL)        | PASS — 0 CRITICAL remaining                                                           |
| Supply-chain audit (no BLOCK) | PASS — typosquat + HTTP repo removed                                                  |
| JaCoCo 80% coverage           | ⚠️ Pre-existing failure (Issue #6 — intentional in demo, not caused by these changes) |

### Trend vs. Previous Run

| Metric              | main (Grade D) | This PR (2026-06-29)      | Delta |
|---------------------|----------------|---------------------------|-------|
| Health score        | 0 / 100        | 62 / 100 (Grade C)        | +62   |
| CRITICAL CVE deps   | 5              | 0                         | -5    |
| HIGH CVE deps       | 4              | 3 (residual MAJOR_REVIEW) | -1    |
| Supply-chain blocks | 2              | 0                         | -2    |
| Total CVEs          | 70             | 10 (residual)             | -60   |

**Note:** 5 prior depscan PRs (#41, #42, #44, #48, #50) remain open and unmerged — all target the same vulnerable `main`. Health score on `main` is 0/100. Merge one of these PRs to establish a healthy baseline.

### Stakeholder Summary

The `vulnerable-invoice-service` project entered this pipeline cycle carrying 70 CVEs across 8 dependencies, including the actively-exploited Log4Shell vulnerability (CVSS 10.0) and 55 separate jackson-databind deserialization chains — the highest risk tier. Two supply-chain attacks were also embedded: a typosquatted coordinate and a plain-HTTP Maven mirror.

The automated pipeline cleared 60 of those CVEs in one consolidated PR, eliminated both supply-chain attack vectors, and raised the health score from 0 to 62 (Grade D → Grade C). All remaining findings are documented MAJOR\_REVIEW items requiring a human licensing or major-version decision. The fix branch is ready for review; no auto-merge was performed.

Generated by the Dependency & Supply-Chain Plugin — Stage 5 (Audit Trail). Source SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`. Run: 2026-06-29T06:58:00Z.